Ogólne zasady reagowania na incydenty

Materiał edukacyjny do demonstracji. Ogólne zagadnienia bezpieczeństwa informacji.

Zakres materiału

Uogólnione opracowanie edukacyjne. Nie jest tekstem normy ISO/IEC 27001 ani planem reagowania konkretnej organizacji. Pominięto rzeczywiste incydenty, kontakty, kanały zgłoszeń, konfiguracje i plany awaryjne.

Rozpoznanie i zgłoszenie

Podejrzenie incydentu należy zgłosić właściwej funkcji odpowiedzialnej za bezpieczeństwo. Zgłoszenie powinno umożliwiać rozpoznanie zdarzenia i ograniczenie jego skutków.

Ustalenie zakresu

Należy ustalić, jakie informacje, procesy i systemy mogły zostać objęte zdarzeniem, kiedy do niego doszło i jakie są możliwe konsekwencje.

Ochrona dowodów

Działania powinny uwzględniać zabezpieczenie informacji potrzebnych do odtworzenia przebiegu zdarzenia. Materiał dowodowy należy chronić przed nieuprawnioną zmianą lub dostępem.

Ograniczenie skutków i odtworzenie

Należy podjąć działania ograniczające skutki incydentu i przywracające wymagane działanie usług. Współpraca z dostawcami i odbiorcami powinna uwzględniać obowiązki wynikające z umów.

Działania po incydencie

Należy udokumentować zdarzenie, ustalić przyczyny, ocenić skuteczność zabezpieczeń i wskazać działania zmniejszające ryzyko powtórzenia.

Ciągłość działania

Dla istotnych usług należy określić potrzeby odtworzenia, dostępności danych i minimalnego poziomu działania. Planowane rozwiązania wymagają sprawdzenia, ale niniejszy materiał nie określa żadnych rzeczywistych czasów, progów ani wyników testów.